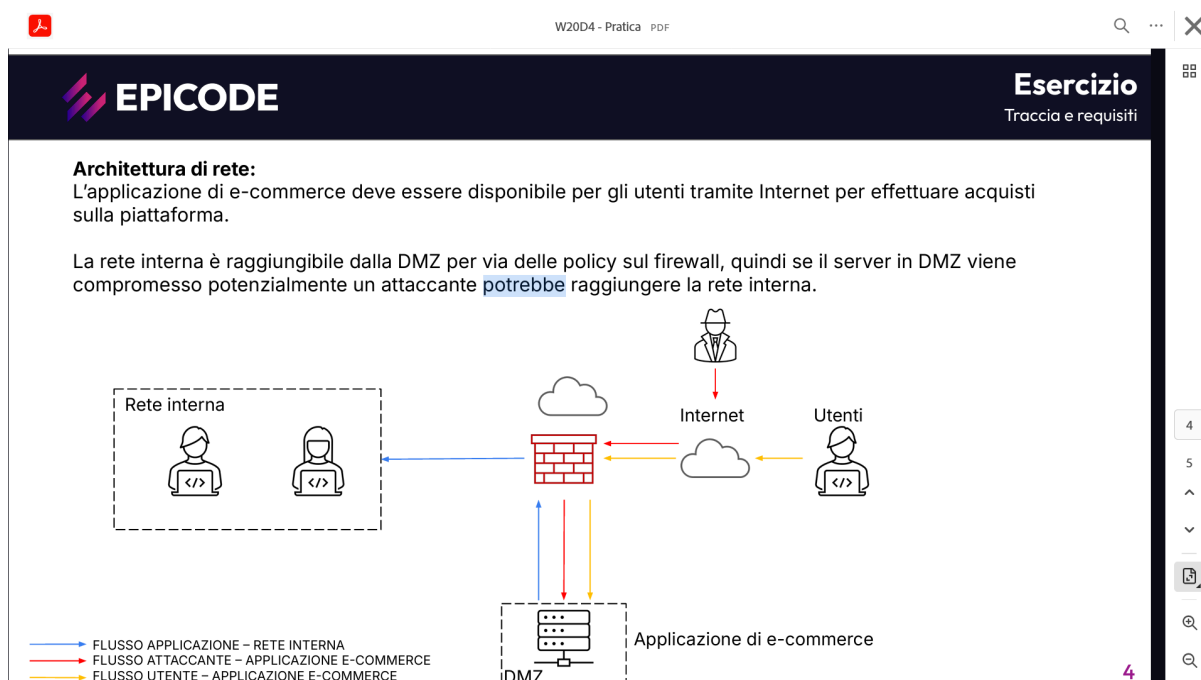


## Report 11/05/2026

### Alunno : Pancrazio Giuzio

Traccia: Esercizio Traccia e requisiti Con riferimento alla figura in slide 2, rispondere ai seguenti quesiti. 1. Azioni preventive: quali azioni preventive si potrebbero implementare per difendere l'applicazione Web da attacchi di tipo SQLi oppure XSS da parte di un utente malintenzionato? Modificate la figura in modo da evidenziare le implementazioni 1. Impatti sul business: l'applicazione Web subisce un attacco di tipo DDoS dall'esterno che rende l'applicazione non raggiungibile per 10 minuti. Calcolare l'impatto sul business dovuto alla non raggiungibilità del servizio, considerando che in media ogni minuto gli utenti spendono 1.500 € sulla piattaforma di e-commerce. Fare eventuali valutazioni di azioni preventive che si possono applicare in questa problematica 1. Response: l'applicazione Web viene infettata da un malware. La vostra priorità è che il malware non si propaghi sulla vostra rete, mentre non siete interessati a rimuovere l'accesso da parte dell'attaccante alla macchina infettata. Modificate la figura in slide 2 con la soluzione proposta. 1. Soluzione completa: unire i disegni dell'azione preventiva e della response (unire soluzione 1 e 3 1. Modifica «più aggressiva» dell'infrastruttura (se necessario/facoltativo magari integrando la soluzione al punto 2



Svolgimento:

L'attuale infrastruttura di rete presenta una configurazione classica ma con punti di vulnerabilità critici. L'applicazione e-commerce, pur essendo confinata in una zona demilitarizzata (DMZ), funge da "ponte" potenziale tra il traffico pubblico di Internet e il cuore pulsante dell'azienda: la Rete Interna.

Possiamo vedere nella slide, la presenza di flussi comunicativi aperti tra la DMZ e la Rete Interna (la freccia blu) espone l'organizzazione a un rischio elevato: se un attaccante riuscisse a prendere il controllo del web server, avrebbe già una "porta aperta" verso i dati sensibili aziendali.

L'obiettivo di questo report è definire una strategia di difesa migliore.

## 1. Difesa dalle Vulnerabilità Web (SQLi e XSS)

Il primo livello di difesa deve concentrarsi sulla "pulizia" del traffico. Attacchi come la SQL Injection (SQLi) e il Cross-Site Scripting (XSS) sfruttano le debolezze nel modo in cui l'applicazione elabora i dati inseriti dagli utenti.

La soluzione ottimale è l'introduzione di un WAF (Web Application Firewall), apre ogni singolo pacco (il contenuto HTTP) alla ricerca di istruzioni malevole.

Il WAF va posizionato tra il firewall perimetrale e il server e-commerce. Parallelamente, gli sviluppatori devono implementare la validazione degli input e le query parametrizzate: in questo modo, anche se un comando malevolo dovesse sfuggire al WAF, il Database lo tratterebbe come semplice testo inutile e non come un ordine da eseguire.

2

Passando all'analisi del se per filtrare milioni di connessioni contemporanee tipiche di un attacco distribuito e rischierebbe di andare in crash insieme al server. La soluzione più efficace consiste nello spostare la difesa a un livello superiore, adottando sistemi di mitigazione esterni gestiti da provider specializzati come Cloudflare, AWS. Questi servizi agiscono come un filtro massivo che pulisce il traffico prima ancora che colpisca il nostro server e-commerce, assicurando che solo gli utenti legittimi possano interagire con la piattaforma e mantenendo così la continuità del business anche durante le fasi più acute di un attacco.

3

Quando ci troviamo a gestire un'infezione da malware già in corso sul server e-commerce, la strategia cambia radicalmente: non siamo più in una fase di prevenzione, ma di contenimento dei danni. In questo scenario specifico, il nostro obiettivo primario non è espellere immediatamente l'intruso o bonificare la macchina compromessa, ma erigere una barriera invalicabile che impedisca al codice malevolo di spostarsi dal server infetto verso i sistemi sensibili della rete interna. Per ottenere questo risultato dobbiamo intervenire sulle regole di comunicazione gestite dal firewall centrale. Guardando lo schema, l'azione più efficace consiste nell'interrompere completamente il flusso rappresentato dalla freccia blu. Questo significa configurare il firewall affinché rifiuti ogni tentativo di connessione che parta dal server in DMZ e sia diretto verso i computer o i database dell'ufficio. Così facendo, anche se l'attaccante ha il pieno controllo della macchina e-commerce e sta cercando di scansionare la nostra rete per rubare altri dati, troverà ogni strada sbarrata. Mantenendo invece attive le connessioni verso l'esterno, come richiesto, permettiamo paradossalmente all'attaccante di continuare la sua attività sul server infetto. Questa scelta può sembrare rischiosa, ma in un'ottica di analisi forense ci permette di osservare il comportamento del malware e le tecniche usate dall'intruso senza mettere in pericolo il resto dell'azienda. A livello visivo sulla nostra figura, questa operazione si traduce nell'eliminazione del

collegamento tra il firewall e la rete interna, lasciando però intatti i percorsi che portano verso l'utente esterno.

4

L'infrastruttura finale si presenta come un ecosistema protetto a più livelli. All'esterno, prima ancora che il traffico raggiunga il nostro firewall, i servizi di scrubbing di Cloudflare o Google Cloud Armor filtrano i picchi di traffico DDoS. Una volta che i dati arrivano al nostro perimetro, il WAF analizza le richieste HTTP per bloccare tentativi di SQLi e XSS diretti al server e-commerce. Infine, la modifica più profonda riguarda la gestione dei flussi interni: abbiamo trasformato la comunicazione con la rete aziendale in un sistema isolato. Il firewall ora agisce come una valvola di sola sicurezza, impedendo al server e-commerce di avviare qualsiasi connessione verso l'interno, neutralizzando così la capacità di movimento di un eventuale malware.